

Motivacija

Prevare u bankarskim transakcijama su sve veći problem u finansijskom sektoru. Gubici u svetu prelaze 30 milijardi dolara godišnje, a načini na koje prevaranti rade postaju sve sofisticiraniji - od krađe kartica, preko preuzimanja tuđih naloga, pa sve do prevara u kojima žrtva sama, pod uticajem manipulacije, pošalje novac.

Stari sistemi koji rade po fiksnim pravilima (na primer „blokiraj svaku transakciju veću od 1000€“) više nisu dovoljni. Oni prave previše lažnih alarma, a istovremeno propuštaju ozbiljne prevare koje se prepoznaju tek kroz obrazac ponašanja. S druge strane, sistemi koji koriste veštačku inteligenciju često ne mogu da objasne zašto su nešto označili kao sumnjivo, što je problem i za zakon i za poverenje klijenata.

Sistem zasnovan na pravilima rešava oba problema: pravila su jasna i razumljiva, lako se menjaju kada se pojavi nova vrsta prevare, a mogu da prate i ponašanje klijenta kroz vreme.

Pregled problema

Cilj ovog sistema je da u realnom vremenu prepozna i klasifikuje sumnjive bankarske aktivnosti. Fokus je na četiri glavne vrste prevara:

- Kartične prevare - zloupotreba kartica na POS terminalima, online plaćanjima i bankomatima, kao i „card testing“ napadi gde prevarant izvršava više malih transakcija da bi proverio da li ukradena kartica radi.
- Preuzimanje naloga - neko je došao do tuđih pristupnih podataka i koristi nalog sa novog uređaja, menja lozinku, dodaje nove primaoce.
- Pranje novca kroz lance transfera - novac brzo ulazi i izlazi sa naloga, šalje se mnogim primaocima u malim iznosima, ili se odjednom aktivira nalog koji je dugo bio neaktivan.
- Autorizovane prevare - žrtva sama izvrši transfer jer je neko prevario (lažni inspektor, lažna investicija). Ovo je najteža kategorija jer transakciju zaista odobrava pravi vlasnik naloga.

Pregled literature pokazuje da postojeća komercijalna rešenja (na primer SAS Fraud Management, FICO Falcon, Feedzai) kombinuju mašinsko učenje sa pravilima, ali su zatvorenog koda. Akademski istraživanja uglavnom koriste mašinsko učenje koje daje dobre rezultate, ali ne može da objasni svoje odluke i sporo se prilagođava novim vrstama prevara. Ovo rešenje prevazilazi te slabosti kroz objašnjivost, praćenje obrazaca u vremenu, brzo prilagođavanje kroz template, i mogućnost dijagnostičkih upita kroz backward chaining.

Status implementacije

Ova specifikacija je usklađena sa stvarnim stanjem implementiranog sistema. Sistem pokriva sva četiri mehanizma rezonovanja:

Mehanizam	Status	Obim
Forward chaining	Implementirano	4 nivoa (atributi → agregacija → skor → akcija) +

Mehanizam	Status	Obim
		accumulate
CEP	Implementirano	6 pravila u stream modu, demo skripta sa pseudo satom
Backward chaining	Implementirano	3 hipoteze (Money Mule rekurzija, Account Takeover, APP Scam)
Template	Implementirano	3 template- a generisana iz Excel tabela

Metodologija rada

Sistem ima tri tipa korisnika: klijent banke, analitičar prevara (fraud analyst) i administrator sistema.

Klijent

Klijent koristi normalne bankarske usluge (kartično plaćanje, online prenos, ATM podizanje, prijava na e- banking). U slučaju da sistem detektuje sumnjivu aktivnost, klijent dobija notifikaciju sa zahtevom za potvrdu (step- up autentifikacija) ili obaveštenje o blokadi. U implementaciji, klijent ima ograničen pristup - vidi samo svoje transakcije, a stranice sa sistemskom analitikom i upozorenjima dostupne su samo analitičaru i administratoru.

Analitičar prevara

Analitičar dobija listu transakcija i klijenata označenih kao srednji ili visoki rizik. Za svaki slučaj može da vidi listu pokrenutih pravila i flagova, kao i da pokrene dijagnostički upit unazad („zašto je ovaj klijent označen kao moguća žrtva account takeover napada?“). Analitičar potvrđuje, odbacuje ili eskalira slučaj. U implementaciji, kada analitičar potvrdi alert, klijent ostaje na watchlist; kada odbaci kao lažni alarm, sistem uklanja flagove te transakcije i skida klijenta sa watchlist.

Administrator

Administrator održava bazu znanja: dodaje zemlje na crnu/sivu listu, definiše segmente klijenata (VIP, redovni, mladi, penzioneri), menja cut- off vrednosti i pragove kroz mehanizam template pravila. Izmenom Excel tabele parametara i regeneracijom pravila, promene se primenjuju bez izmene koda.

Ulaz u sistem

Ulaz u sistem čine sledeći tokovi podataka:

- Statički podaci o klijentu - godine, segment (VIP/redovni/mladi/penzioner), datum otvaranja računa, država prebivališta, prosečan mesečni promet, lista poznatih primalaca, lista poznatih uređaja.
- Stream transakcija u realnom vremenu - svaka transakcija sadrži: ID klijenta, iznos, valutu, vreme, kanal (POS/online/ATM/transfer), lokaciju (zemlja, grad, IP), merchant ID i kategoriju, ID uređaja.

- Stream login događaja - vreme, IP, geo- lokacija, fingerprint uređaja, rezultat (uspeh/neuspeh), tip autentifikacije.
- Promene na nalogu - promena lozinke, dodavanje novog primaoca, povećanje limita, promena kontakt podataka.
- Eksterne liste - crna lista zemalja/IP- ova/merchant- a, lista poznatih „mula“ računa, lista kompromitovanih kartica.

Izlaz iz sistema

Izlazi sistema su gradirani prema nivou rizika, pri čemu se akcije eskaliraju sa rastom skora rizika:

- Nizak rizik (skor 0–30): transakcija prolazi normalno, događaj se loguje, profil klijenta se ažurira.
- Srednji rizik (skor 30–60): transakcija prolazi, ali se kreira upozorenje (alert) u redu za pregled analitičaru. Klijent se dodaje na watchlist.
- Visok rizik (skor 60–85): transakcija se blokira do potvrde, klijent dobija step- up autentifikaciju (SMS kod ili push potvrda).
- Kritičan rizik (skor 85+): automatska blokada, privremeno zamrzavanje naloga, hitan kontakt klijentu, prijava nadležnoj službi za sprečavanje pranja novca (AML) kada je potrebno.

Pored ovoga, sistem proizvodi dijagnostičke izveštaje (rezultat backward chaining- a) i statističke preglede o mehanizmima rezonovanja.

Baza znanja

Pravila su grupisana po kategorijama prevara i nivoima rezonovanja.

1. Inicijalni profil klijenta

Kada se klijent prvi put obrađuje, prikupljaju se osnovni podaci: starost, segment, država prebivališta, prosečan mesečni promet, lista poznatih uređaja i primalaca. Klijentu se dodeljuje povišen profil rizika ukoliko: račun je otvoren u poslednjih 30 dana uz visok obrt; klijent pripada segmentu „mladi“ (18–25) ili „penzioneri“ (65+); država prebivališta je na sivoj listi (FATF); klijent je u poslednjih 12 meseci imao potvrđen slučaj prevare; ili klijent ima istoriju neuspelih KYC provera.

2. Kartične prevare (POS, online, ATM)

Kada stigne kartična transakcija, sistem nad njom izračunava izvedene attribute i proverava obrasce ponašanja. Transakcija se označava kao sumnjiva ukoliko:

- Iznos prelazi 5x prosečan iznos klijenta → flag abnormalno visoka.
- Transakcija je između 02:00 i 05:00 lokalno → flag neuobičajeno vreme.
- Transakcija je iz zemlje na sivoj listi → flag rizična lokacija.
- Merchant kategorija je visokog rizika (kockanje, kripto, prepaid) → flag rizičan merchant.

- Transakcija je sa novog uređaja → flag nepoznat uređaj.

3. Preuzimanje naloga (Account Takeover)

Najopasniji scenario jer napadač ima legitiman pristup nalogu. Sistem prati login događaje, promene na nalogu i transakcije iz vremenskog prozora od 7 dana. Klijentu se dodeljuje rizik od preuzimanja naloga ukoliko: detektuje se 5+ neuspelih prijava u roku od 5 minuta (CEP burst); uspešna prijava je sa nepoznatog uređaja; prijava dolazi iz geografski nemoguće daleke zemlje (impossible travel - CEP); klijent menja kontakt podatke u roku od 24h od sumnjive prijave; klijent dodaje novog primaoca; ili se pokušava transfer ka novom primaocu sa visokim iznosom.

4. Money mule račun (pranje novca)

Mula nalozi se koriste za prosleđivanje novca. Sistem prati životni ciklus naloga, obrasce priliva i odliva u prozoru od 48 sati. Klijentu se dodeljuje rizik mula naloga ukoliko: nalog je nedavno otvoren ili reaktiviran posle 90+ dana mira; stiže priliv značajnog iznosa od nepoznatog uplatioca; u 24h broj različitih primalaca je veći od 10 uz prosečan iznos manji od 200€ (accumulate); odnos odliva i priliva u 48h prelazi 0.9; ili više od 3 primaoca su novootvoreni/inostrani računi.

Backward chaining hipoteza „Money Mule“ potvrđuje slučaj kada postoji lanac prosleđivanja novca kroz proizvoljno mnogo posrednika, što se proverava rekursivnim upitom (sekcija Backward chaining).

5. Autorizovana prevara - APP scam

Najsuptilniji slučaj jer pravi vlasnik sam izvršava transfer pod uticajem prevare. Sistem prati i ponašanje klijenta pre transakcije. Rizik se dodeljuje ukoliko: transfer ide ka ranije nekorišćenom primaocu; iznos je značajno veći od proseka ($>3x$); klijent je pre transfera obavljao neuobičajene radnje (pretrage limita, čitanje uputstava, neuspeli transferi) → obrazac pod stresom; klijent pripada osetljivom segmentu (multiplikator $\times 1.3$); ili je primalac u zemlji bez čvrste regulative. Sistem ne blokira automatski već pokreće „cooling-off“ mehanizam.

6. Sinteza skora i odluka o akciji

Pošto pravila proizvedu flagove sa težinama, sistem računa ukupan skor i donosi odluku:

- Bazni skor = zbir težina svih aktivnih flagova u poslednjih 24h.
- VIP segment: skor za male iznose se umanjuje za 20%.
- Kombinacija 3+ kritičnih flagova: multiplikator 1.2.
- Skor 0–30 → loguj; 30–60 → alert + watchlist; 60–85 → blokada + step- up; 85+ ili na watchlist → zamrzni + AML.
- 3+ blokade istog klijenta u 7 dana → automatska eskalacija analitičaru.

Ovaj nivo predstavlja vrh forward chaining lanca - pravila rade nad zaključcima iz prethodnih koraka (atributi → flagovi → agregati → skor → akcija).

Kompleksna pravila: CEP (Complex Event Processing)

CEP modul prati tokove transakcija i login događaja u realnom vremenu i detektuje obrasce koji se ne mogu uočiti gledanjem pojedinačne transakcije. KieBase radi u stream modu (eventProcessingMode="stream"), a događaji (Transaction, LoginEvent, Flag) deklarirani su sa @Role(EVENT), @Timestamp i @Expires. Implementirano je 6 CEP pravila:

- Velocity attack (card testing): 5+ transakcija za istu karticu u 60 sekundi - sliding window over window:time(60s).
- Impossible travel: dve transakcije/logina na lokacijama čija razdaljina prevazilazi maksimalno moguće putovanje u vremenskom intervalu (temporalni operator before, GeoUtil haversine formula).
- Structuring (smurfing): 3+ transakcije u 48h sa iznosima ispod regulatornog praga prijave - accumulate sa filterom po iznosu i klijentu.
- Burst pattern nakon mirovanja: nalog neaktivan 90+ dana, pa 3+ transakcije ka različitim primaocima u jednom danu.
- Failed login burst: 5+ neuspešnih prijava u 5 min, pa uspešna prijava sa novog uređaja → suspicious_login događaj.
- Suspicious login: uspešna prijava sa nepoznatog uređaja posle burst- a neuspešnih (temporalni operator before unutar accumulate).

Demonstracija CEP- a - pseudo sat

Pošto CEP prozori traju i do 48 sati, demonstracija u realnom vremenu nije praktična. Zato je implementirana skripta sa pseudo satom (SessionPseudoClock) koja je integrisana u sistem (Spring komponenta, ne spoljašnji alat). Skripta ubacuje događaje raspoređene kroz simulirano vreme i pomera sat metodom advanceTime(), pa se svih 6 CEP prozora demonstrira odjednom. Generisani flagovi i alerti ostaju u radnoj memoriji i vide se na frontendu (stranica Upozorenja), jer skripta i frontend dele istu KieSession.

```
// Pokretanje sa argumentom cep- demo:
mvn spring- boot:run "- Dspring- boot.run.arguments=cep- demo"

// Skripta koristi istu kieSession (pseudo clock):
SessionPseudoClock clock = kieSession.getSessionClock();
clock.advanceTime(48, TimeUnit.HOURS);
kieSession.insert(event);
kieSession.fireAllRules();
```

Forward chaining

Forward chaining je osnovni mehanizam rezonovanja. Pravila se okidaju automatski kada nove činjenice (transakcije, login događaji, promene na nalogu) uđu u radnu memoriju, pri čemu se zaključci jednog pravila koriste kao ulaz za sledeće. Lanac ima 4 nivoa:

- **Nivo 1 - Atributi transakcije:** pravila izračunavaju izvedene attribute i dodeljuju flagove poput abnormalno visoka, rizična lokacija, nepoznat uređaj.

- **Nivo 2 - Agregacija (accumulate):** pravila koriste accumulate nad transakcijama klijenta u prozoru (24h, 48h, 7 dana) - broj primalaca, odnos odliva/priliva. Rezultat su agregirani flagovi.
- **Nivo 3 - Sinteza skora rizika:** pravila sumiraju težine flagova, primenjuju multiplikatore za segment i kombinacije kritičnih flagova, računaju ukupan skor.
- **Nivo 4 - Odluka o akciji:** pravila na osnovu skora i istorije odlučuju o akciji (prolaz, alert, step- up, zamrzavanje). Okidaju se i kumulativna pravila.

Accumulate se koristi na više mesta u Nivou 2: prebrojavanje neuspešnih prijava, broj različitih primalaca, sumiranje iznosa u prozoru, izračunavanje odnosa odliva i priliva.

Backward chaining

Backward chaining (ulančavanje unazad) koristi se za dijagnostiku. Za razliku od forward chaining- a koji se okida automatski, backward chaining se pokreće na zahtev - analitičar postavi cilj, a sistem unazad traži činjenice koje ga podržavaju. U Drools- u se realizuje konstrukcijom query. Implementirane su tri hipoteze, dostupne analitičaru kroz stranicu Dijagnostika.

Hipoteza 1 - Money Mule: rekurzivni upit

Pranje novca se ne može prepoznati gledanjem jednog transfera. Novac putuje kroz lanac mula naloga proizvoljne dužine ($A \rightarrow B \rightarrow D \rightarrow G$). Lanac se gradi nad klasom Transaction - odlivi se identifikuju filterom `inflow == false`, gde `clientId` igra ulogu pošiljaoca a `recipientId` primaoca. Pitanje „da li novac sa računa A stiže do računa G kroz proizvoljno mnogo posrednika?“ zahteva rekurzivni upit sa dve grane:

```
query reaches( String from, String to )
  // baza rekurzije
  Transaction( clientId == from, recipientId == to, inflow == false )
  or
  // rekurzivni korak
  ( Transaction( clientId == from, $z : recipientId, inflow == false )
    and reaches( $z, to; ) )
end
```

Filter `inflow == false` je suštinski - bez njega bi upit obilazio činjenice u oba smera. `$z` je nevezana promenljiva koju Drools popuni svakom vrednošću `recipientId` za dati `from`, pa se nad njom rekurzivno traži ostatak lanca. Pošto je Transaction event sa `@Expires("49h")`, upit gleda samo lance iz poslednjih 49 sati.

Hipoteza 2 - Account Takeover

Forward chaining već generiše Flag činjenice u radnoj memoriji (BRUTE_FORCE_POKUSAJ, SUSPICIOUS_LOGIN, IZMENA_KONTAKT_PODATAKA, NOVI_PRIMALAC, ABNORMALNO_VISOKA). Backward chaining query ne traži sirove događaje, već kombinaciju ovih flagova kao dokaz hipoteze. ATO se potvrđuje kombinacijom: (a) kompromitovan pristup I (b) ILI c) izmena kontakta ili novi primalac I (d) abnormalan transfer. Pomoćni upit `compromisedAccess` je ugnežđen cilj:

```
query compromisedAccess( String acc )
  Flag( clientId == acc, type == FlagType.BRUTE_FORCE_POKUSAJ )
  or
  Flag( clientId == acc, type == FlagType.SUSPICIOUS_LOGIN )
end

query accountTakeover( String acc )
  compromisedAccess( acc; ) // (a)
  ( Flag( clientId == acc, type == FlagType.IZMENA_KONTAKT_PODATAKA )
    or Flag( clientId == acc, type == FlagType.NOVI_PRIMALAC ) ) // (b ILI c)
  Flag( clientId == acc, type == FlagType.ABNORMALNO_VISOKA ) // (d)
end
```

Hipoteza 3 - APP scam

Forward chaining generiše flagove PRVI_TRANSFER_KA_PRIMAOCU, ABNORMALNO_VISOKA, OBRAZAC_POD_STRESOM, OSETLJIV_SEGMENT. Cilj se potvrđuje kao (a) prvi transfer ka primaocu I (b) neuobičajen iznos I (c Ili d) indikator stresa ili osetljiv segment:

```
query appScam( String acc )
  Flag( clientId == acc, type == FlagType.PRVI_TRANSFER_KA_PRIMAOCU ) // (a)
  Flag( clientId == acc, type == FlagType.ABNORMALNO_VISOKA )         // (b)
  ( Flag( clientId == acc, type == FlagType.OBRAZAC_POD_STRESOM )     // (c)
    or Flag( clientId == acc, type == FlagType.OSETLJIV_SEGMENT ) )   // (d)
end
```


Template

Template pravila omogućavaju administratoru da menja parametre baze znanja bez prekompajliranja. Logika pravila se piše jednom, sa „prazninama“ oblika `@{parametar}`, a konkretne vrednosti dolaze iz tabele parametara. Iz jednog template- a i jedne tabele Drools generiše po jedno konkretno pravilo za svaki red tabele.

A) Pragovi rizika po segmentima - risk_thresholds

Cut- off vrednosti skora razlikuju se po segmentu - VIP klijenti imaju viši prag za blokadu, dok osetljivi segmenti imaju niže. Iz tabele se generišu 4 pravila (po jedno za svaki segment). Pravilo prevodi numerički skor klijenta u nivo rizika (LOW/MEDIUM/HIGH/CRITICAL).

Segment	alertCut	blockCut	freezeCut
VIP	35	70	90
redovni	30	60	85
mladi (18–25)	25	50	80
penzioneri (65+)	25	50	80

Ako administrator podigne blockCut za VIP sa 70 na 75, sistem to koristi odmah, bez izmene koda.

B) Crna i siva lista zemalja - country_lists

Administrator dodaje ili uklanja zemlje; template generiše pravilo evaluacije po zemlji. Crna lista nosi veću težinu (40), siva manju (15). Template ima dva rule bloka - za zemlju porekla (country) i za zemlju primaoca (recipientCountry, kanal TRANSFER) - pa iz 10 zemalja generiše 20 pravila.

countryCode	listType	weight
KP, IR, MM, SY, CU	crna	40
PA, KY, AE, MT, CY	siva	15

C) Visokorizični MCC kodovi - mcc_risk

Konfigurabilna lista MCC (Merchant Category Code) kodova; svaki nosi sopstvenu težinu flega rizičan merchant. Iz tabele se generiše 5 pravila.

MCC	kategorija	weight
7995	kockanje / klađenje	25
6051	kripto- menjačnice	25
6050	quasi- cash	20
6540	prepaid kartice	20
4829	novčani transferi	20

Konkretan primer rezonovanja (korak po korak)

U nastavku je scenario u kome se kombinuju sva tri napredna mehanizma (forward chaining sa accumulate, CEP i backward chaining).

Scenario: Klijentkinja Marija (45 godina, segment „redovni“, prosečan mesečni promet 2.500€, prebivalište Srbija) je žrtva account takeover napada. Sled događaja:

1. U 22:14 - 5 neuspešnih pokušaja prijave u 3 minuta sa IP iz Holandije.
2. U 22:18 - uspešna prijava sa istog IP- a, sa nepoznatog uređaja.
3. U 22:21 - promena email adrese za notifikacije.
4. U 22:25 - dodavanje novog primaoca (račun u inostranoj banci).
5. U 22:27 - pokušaj transfera od 4.800€ ka novom primaocu.

Korak 1 - CEP detekcija sumnjivog logina

CEP modul detektuje obrazac „failed login burst → successful login from new device“ u događajima 1 i 2. Generiše se činjenica SuspiciousLogin koja ulazi u radnu memoriju i postaje okidač za dalja pravila.

Korak 2 - Forward chaining, Nivo 1 (atributi)

Kada u 22:27 stigne transfer, Nivo 1 izračunava: iznos 4800 je abnormalno visok; primalac je nov; vreme je neuobičajeno; uređaj je nepoznat. Generišu se odgovarajući flagovi.

Korak 3 - Forward chaining, Nivo 2 (accumulate)

Pravilo sa accumulate prebrojava promene na nalogu u poslednjih 60 minuta (promena email- a + novi primalac = 2). Zaključuje da je u toku burst aktivnosti.

Korak 4 - Forward chaining, Nivo 3 (skor)

Pravilo sinteze sumira težine flagova: nepoznat uređaj (15) + abnormalno visoka (20) + novi primalac (15) + neuobičajeno vreme (10) + suspicious login (25) + burst (20) = bazni skor 105. Kombinacija 3+ kritičnih → multiplikator 1.2. Template risk_thresholds za segment „redovni“ klasifikuje skor kao KRITIČAN RIZIK.

Korak 5 - Forward chaining, Nivo 4 (akcija)

Pravilo eskalacije: zbog kritičnog skora transakcija se BLOKIRA, nalog se ZAMRZAVA, generiše se hitan alert, klijentkinja se kontaktira telefonskim pozivom (ne email- om, jer je email već promenjen).

Korak 6 - Backward chaining (dijagnostika)

Analitičar otvara slučaj i poziva accountTakeover("MARIJA_001";). Sistem proverava Flag činjenice koje je forward chaining već stvorio:

- (a) compromisedAccess → DA (BRUTE_FORCE_POKUSAJ iz Koraka 1).
- (b) IZMENA_KONTAKT_PODATAKA → DA (promena email- a u 22:21).

- (c) NOVI_PRIMALAC → DA (OR grana, jedno je dovoljno).
- (d) ABNORMALNO_VISOKA → DA (transfer 4.800€).

Sistem vraća: hipoteza POTVRĐENA. Analitičar dobija strukturirano objašnjenje (tačnu listu flagova), kontaktira klijentkinju, vraća lozinku, uklanja kompromitovanog primaoca i prijavljuje slučaj.